

Attack Scenarios – Catalog tấn công THẬT lên dữ liệu vị trí

Khảo sát 2026-08-20 (5 research agents song song, nguồn primary đã verify khi có thể). Mục tiêu: liệt kê các **sự cố thật** và **paper tấn công có mục tiêu thật** để xây kịch bản đánh giá luận văn bám vào thực tế thay vì threat model tự nghĩ ra. File này là bản deep-dive đi kèm `system_model_and_threats.md` (mục 3 của file đó tóm tắt taxonomy S1–S8; file này là chi tiết đầy đủ 5 nhóm tấn công + citations).

Cách đọc: Mục 1–5 là 5 nhóm tấn công (kèm bảng + URL). Mục 6 là **taxonomy 8 kịch bản (S1–S8)**, mỗi kịch bản ghi rõ (a) năng lực đối thủ, (b) dữ liệu họ thấy, (c) thuộc tính phòng thủ hóa giải — ánh xạ trực tiếp vào cơ chế `REM` / `T-REM` / `BaselineThesis` và code trong `evaluation/`. Mục 7 là **khuyến nghị bước tiếp theo** (bám `Notes.md`). Mục 8 là các điểm chưa chắc chắn.

Lưu ý nguồn: vài URL primary (Include Security, Guardian, NYT interactive, WSJ, một số ACM paywall) chặn fetch tự động nhưng đã đối chiếu qua nhiều nguồn thứ cấp. Các con số đọc trực tiếp từ PDF gốc được giữ nguyên; chỗ không verify được đánh dấu (*flag*).

1. Trilateration / proximity trên app hẹn hò & social

Ý nghĩa cho luận văn: đây là bằng chứng thực tế mạnh nhất rằng **làm tròn khoảng cách / "ẩn khoảng cách" KHÔNG phải là guarantee** — chỉ cơ chế indistinguishability hình thức (Geo-I, grid-snap trước khi tính distance) mới chặn được. Bám vào kịch bản **S1**.

#	App / Năm	Researcher	Quan sát	Suy ra	Kỹ thuật / vì sao phòng thủ hỏng	URL
1	Tinder / 2013	Max Veytsman, Include Security	lat/long thô ~15 chữ số (tính distance ở client)	vị trí chính xác	Không obfuscation; gửi thẳng toạ độ về client	includesecurity.com ; theregister
2	Tinder / 2014	Veytsman, Include Security	<code>distance_mi</code> là double 64-bit (chính xác cm) dù UI hiện số mile nguyên	vị trí ~30 m	Exact-distance trilateration (3 tài khoản giả). Chuyển tính về server không giảm precision; fix = làm tròn về số nguyên	blog.includesecurity.com (403 với bot; vẫn sống)

#	App / Năm	Researcher	Quan sát	Suy ra	Kỹ thuật / vì sao phòng thủ hỏng	URL
3	Grindr / 2014 (ShmooCon '15)	Colby Moore & Patrick Wardle, Synack	API "all nearby users" không auth, distance chính xác, không rate-limit	~15.000 user SF bị định vị + theo dõi	Trilateration + thu hoạch hàng loạt	securityweek ; bbc
4	Grindr/Jack'd/Hornet / 2016	Hoang, Asano, Yoshikawa (Kyoto)	distance tới user gần — kể cả khi tắt "show distance"	vị trí chính xác	"Colluding-trilateration"; thứ tự sắp xếp theo khoảng cách là side channel sống sót sau khi ẩn số	arxiv 1604.08235
5	Grindr / 2018	Trever Faden ("C*ckblocked")	API qua site trung gian: tin nhắn, ảnh đã xoá, email, vị trí chính xác ; GPS+HIV chia sẻ cho Apptimize/Localytics	vị trí + danh tính	Precision vẫn cao sau nhiều năm; data chia sẻ bên thứ 3	buzzfeednews
6	Grindr / 2024 (USENIX Sec)	Dhondt, Le Pochat et al., KU Leuven	distance chính xác đến mét , kể cả user ẩn distance / ở nước bị ép ẩn (Egypt)	$\phi \geq 111$ $m \times 111$ m	Trilateration + oracle 1 tài khoản mới (grid nearby vẫn sắp theo distance). Làm tròn toạ độ 3 chữ số (~111 m) bị đánh giá là chưa đủ ở vùng thưa	usenix ; PDF leepoch.at
7	Bumble / 2021	Robert Heaton	distance làm tròn xuống mile gần nhất	vị trí đến toà nhà (pin trúng FBI SF HQ)	Oracle trên bước làm tròn : điểm "lật" (3→4 mi) lộ distance chính xác khi đã biết cách làm tròn → 3 điểm lật → trilateration	robertheaton.com

#	App / Năm	Researcher	Quan sát	Suy ra	Kỹ thuật / vì sao phòng thủ hồng	URL
8	Bumble/Hinge/Badoo/Hily / 2024	Dhondt et al., KU Leuven	bộ lọc distance dùng như oracle nhị phân (nội bộ dùng distance chính xác dù UI ẩn)	pin ~2 m	Oracle trilateration: dịch chuyển đến khi filter lật ở 3 hướng. "Ẩn distance" vô dụng vì filter là side channel	techcrunch
9	happn / 2024	Dhondt et al.	API lộ distance mịn hơn UI (bucket 249/499/999/1999 m)	~2 m	UI làm tròn bị phá bởi giá trị mịn hơn trong API	leepoch.at PDF
10	Kaspersky "Dangerous Liaisons" 9 app / 2017	Kaspersky (Unuchek et al.)	distance hiển thị; field nghề/học vấn	trilateration + ~60% de-anon ra FB/LinkedIn	distance đủ chính xác để triangulate; truyền dữ liệu không an toàn	securelist
11	Grindr/Romeo/Recon/3fun / 2019	Alex Lomas, Pen Test Partners	lat/long 8 chữ số (sub-mm)	pin "đến từng nhà"	obfuscation tắt mặc định/giấu kỹ; snap-to-grid hứa nhưng chưa deploy	pentestpartners
12	LOVOO / 2019 → đã fix	"posixpascal" PoC	API public lộ distance chính xác	~10 m	Sau này fix bằng grid snap 1x1 km — KU Leuven 2024 xác nhận hiệu quả (LOVOO & Tinder là 2 app KHÔNG dính năm 2024)	github/posixpascal

Phụ: POF exact-distance (2014, ref [111] trong USENIX'24); Jack'd 2019 lộ ảnh+location qua S3 mở (phạt \$240k NY AG, [sophos](#)); Polakis "Where's Wally?" CCS 2015 (Facebook đến 5 m, 90% Foursquare đến 15 m — phá phòng thủ rounding/grid trong dịch vụ proximity, [dl.acm.org](#)).

Ba lớp trilateration (khung KU Leuven 2024, rất hợp để trích trong luận văn): (i) **exact-distance**; (ii) **rounded-distance** (điểm lật = distance chính xác); (iii) **oracle** (proximity/filter nhị phân, phá được UI ẩn distance). Biện pháp paper công nhận hiệu quả là **grid snap / spatial indistinguishability áp dụng TRƯỞC khi suy ra distance** — chính là họ Geo-I của luận văn.

2. Fitness app / activity tracker

Ý nghĩa: hai họ ở đây bám thẳng vào đánh giá của luận văn — **thất bại của aggregation ở vùng thưa** và **đảo ngược hình học privacy-zone** (chính nhóm tác giả USENIX đề xuất dùng planar-Laplacian ϵ -geo-indistinguishability = đúng công cụ của luận văn). Bám kịch bản **S4, S7**.

- **Strava Global Heatmap** → **căn cứ quân sự (1/2018), Nathan Ruser (ANU)**. Quan sát: raster tổng hợp ~1 tỷ activity / ~3 nghìn tỷ điểm GPS (không ID). Suy ra: chu vi, đường tuần tra/tiếp tế, "pattern of life" ở căn cứ Mỹ tại Afghanistan/Syria, nghi cơ sở CIA ở Somalia; **định danh được từng lính** qua leaderboard segment (thời điểm đó browse được). Vì sao aggregation hỏng: ở vùng xung đột mật độ thấp chỉ nhân sự phương Tây dùng Strava → dấu vết cô lập, quy được về cá nhân; heatmap **opt-out mặc định**. abc.net.au; money.cnn.com.
- **Strava/Garmin privacy-zone (EPZ) khôi phục nhà — USENIX Security 2018, Hassan, Hussain, Bates (UIUC), "You can run, but can you hide?"** Quan sát: phần route ngoài vòng tròn EPZ + các điểm route cắt biên vòng tròn; auto phát hiện qua chênh lệch giữa distance quảng cáo và distance tính từ GPS thấy được. Suy ra: **tâm vòng tròn = nhà**, sai số vài mét. Kỹ thuật: "EPZ Circle Search Problem" — điểm cắt biên nằm trên vòng tròn, bán kính lấy từ **tập hữu hạn cố định** ($\frac{1}{8}, \frac{1}{4}, \frac{3}{8}, \frac{1}{2}, \frac{5}{8}$ mi), nên 3 điểm cắt là đủ over-determine tâm+bán kính (giao vòng tròn có confidence score). Quy mô/kết quả: scrape **20.9M activity / 2.96M athlete; 2.36M activity EPZ / 432.022 athlete**; khôi phục nhà **84%** (>1 activity EPZ), **95.1%** (≥ 3), **96.6%** trên ground-truth tổng hợp. Fix tác giả đề xuất: **địch chuyển kiểu planar-Laplacian ϵ -geo-indistinguishability / fuzz điểm biên / random bán kính**. usenix.org.
- **EPZ khôi phục mạnh hơn — ACM CCS 2022, Dhondt et al. (KU Leuven), "A Run a Day Won't Keep the Hacker Away."** Quan sát: metadata distance + lưới đường + điểm vào EPZ. Kỹ thuật: **regression** dự đoán tâm. Trên **~1.4M activity Strava**, khôi phục **tới 85%** — cho thấy fix thời 2018 chưa đủ. dl.acm.org.
- **Định danh nhà từ heatmap public — ConPro 2023 (NC State), Childs, Nolting, Das, "Heat Marks the Spot."** Quan sát: heatmap de-identified + tính năng **search theo tên thành phố** (liệt kê mọi user để city đó: tên, ảnh, số activity); ground truth = OSM footprint + **danh sách cử tri** + Google geocoding. Kỹ thuật: chụp 491.463 screenshot heatmap ở zoom mức nhà (AR/OH/NC), trừ nhiệt đường bằng heatmap môn *bơi*, phát hiện "notch" đầu route tại nhà, khớp user, đối chiếu cử tri. Kết quả: **11.165 user** có cả Strava + hồ sơ cử tri; **17/20 user** mục tiêu có notch trong 100 m; **31.7%** phát hiện được ở 100 m (37.5% với user trung bình 308 activity). Hỏng vì "an toàn nhờ số đông" sụp ở vùng thưa; privacy-zone không áp cho đóng góp heatmap tới 8/2022. [PDF](#); news.ncsu.edu.
- **Polar Flow "Explore" API de-anon hàng loạt — Bellingscat + De Correspondent, 7/2018 (Foeke Postma)**. Quan sát: map Explore + API dev trả **toàn bộ lịch sử user từ 2014**, lấy được cả profile non-public. Suy ra: tên, ảnh, **địa chỉ nhà** của nhân sự tình báo/quân đội — **~6.460 user tại 200+ điểm nhạy cảm (~650.000 buổi tập)** thuộc NSA, Secret Service, GCHQ, MI6, GRU, SVR, DGSE, cơ sở hạt nhân/tàu ngầm, Guantánamo. Kỹ thuật: query bounding-box → liệt kê user ID → kéo lịch sử toàn cầu (điểm start/stop lặp = nhà) → đối chiếu LinkedIn. Hỏng vì **không có che nhà tự động**; toggle privacy chỉ áp cho buổi mới; ID buổi "private" vẫn lấy được qua API. bellingscat.com.
- **Định danh cá nhân qua segment giả — 6/2022, FakeReporter (Israel)**. Đối thủ **upload GPS giả để tạo "segment" trong căn cứ mật**; ai từng tập ở đó nổi lên leaderboard. ~100 người tại 6 điểm tối mật (gồm Mossad HQ, gần Dimona); 1 người truy được sang nước ngoài. Vượt qua cả cài đặt privacy *tài khoản* mạnh nhất — đối thủ, không phải nạn nhân, chủ động cấm điểm. forbes.com.
- **Vệ sĩ Säpo Thụy Điển — 2025, Dagens Nyheter**. Runs public của 7 cận vệ **lộ vị trí Thủ tướng Ulf Kristersson 35+ lần** (gồm nhà mật, khách sạn nước ngoài) + hoàng gia. Người được bảo vệ không dùng

app — không cài đặt cá nhân nào cứu được. [nbcnews.com](https://www.nbcnews.com).

- **Rò rỉ wearable (context, không phải tấn công suy luận):** GetHealth 2021 — **61M+** bản ghi Fitbit/Apple Health (tên, DOB, **log GPS**) trong DB không mật khẩu ([fiercehealthcare](https://www.fiercehealthcare.com)). Không tìm thấy vụ de-anon kiểu Strava/Polar riêng cho Apple.

3. Data broker / ad-tech re-identification

Ý nghĩa: đây tấn công dữ liệu quỹ đạo thô, **pseudonym (khóa theo MAID)** — không có cơ chế nhiễu nào. Chúng xác lập **threat model và mức độ nghiêm trọng:** pseudonym ≠ ẩn danh vì bản thân quỹ đạo (điểm ngủ đêm = nhà, ban ngày = chỗ làm) chính là định danh. Bám kịch bản **S6, S8**.

- **Linh mục Msgr. Burrill bị lộ qua data Grindr "ẩn danh" — The Pillar, 7/2021.** Mua "app signal data" thương mại (ping có timestamp + hoạt động app khóa theo MAID), hai cửa sổ 26 tuần. Khớp ID với văn phòng USCCB, nơi ở, các cuộc họp thành phố khác, nhà nghỉ hồ, và một bathhouse gay ở Las Vegas. Kỹ thuật: **reverse-geofence anchor linkage** — ID luôn xuất hiện ở các anchor đã biết, rồi bám theo khắp nơi. [pillarcatholic](https://www.pillarcatholic.com); [washingtonpost](https://www.washingtonpost.com). **Bản công nghiệp hoá:** WaPo 3/2023 — một tổ chức chi **≥\$4M** mua data Grindr/Scruff/Growlr/ Jack'd/OkCupid để định danh linh mục đồng tính đối chiếu địa chỉ nhà xứ toàn quốc ([washingtonpost](https://www.washingtonpost.com)).
- **NYT "Twelve Million Phones, One Dataset, Zero Privacy" — Thompson & Warzel, 12/2019.** Một file rò rỉ: **50B+ ping, 12M+ điện thoại** (2016–17), device ID + lat/long + timestamp. Định danh: quan chức Lầu Năm Góc có clearance, cảnh sát, luật sư, người nổi tiếng, người biểu tình, một kỹ sư Microsoft→Amazon; bài kèm bám theo một **mật vụ Secret Service từ Mar-a-Lago** về tận nhà. Phương pháp: nhà = nơi ngủ đêm, chỗ làm = ban ngày; cặp này khớp tên qua hồ sơ công khai "trong vài phút". Ohm: dữ liệu vị trí chính xác dài hạn "hoàn toàn không thể ẩn danh". [nytimes.com](https://www.nytimes.com).
- **FTC enforcement (hành vi bị cáo buộc):**
 - **Kochava** (đơn 8/2022 → dàn xếp 5/2026): bán geolocation chính xác từ **hàng trăm triệu thiết bị**, khóa MAID, truy được về phòng khám sản khoa, nơi thờ tự, nhà tạm lánh; mẫu miễn phí không ràng buộc. Dàn xếp cấm bán data vị trí nhạy cảm, buộc affirmative consent. [ftc](https://www.ftc.gov) 2022; [ftc](https://www.ftc.gov) 2026.
 - **X-Mode / Outlogic** (1/2024, lệnh CẤM bán data vị trí nhạy cảm ĐẦU TIÊN): data ad-ID thô lộ ghé thăm cơ sở y tế/tôn giáo/LGBTQ+, bán cả cho nhà thầu quốc phòng. [ftc](https://www.ftc.gov).
 - **InMarket** (1/2024): SDK trong ~300 app, vị trí chính xác từ ~100M thiết bị dùng làm segment quảng cáo không thông báo; cấm bán mọi data vị trí chính xác. [ftc](https://www.ftc.gov).
 - **Gravy Analytics/Venntel & Mobilewalla** (3/12/2024): Gravy — 17B+ signal/ngày từ ~1 tỷ thiết bị, list sự kiện nhạy cảm theo geofence; Mobilewalla — thu **vị trí từ RTB bidstream kể cả khi thua bid** (dùng lập hồ sơ người biểu tình Floyd/dân Hồi giáo). [therecord](https://www.therecord.com).
 - **Vụ lộ Gravy (1/2025):** attacker khai **17 TB** (*flag: con số của attacker; mẫu phân tích ~30M bản ghi*) — lat/long+timestamp+ad-ID chính xác từ Tinder, Grindr, Candy Crush, MyFitnessPal, app thai kỳ/giao thông. Cho thấy giả định "curator tin cậy" sụp đổ. [techcrunch](https://www.techcrunch.com).
 - **Muslim Pro / X-Mode → quân đội Mỹ — Joseph Cox, Vice, 11/2020.** SDK X-Mode trong ~400 app (~25M thiết bị Mỹ/tháng), gồm Muslim Pro (98M+ tải); GPS+ad-ID bán lại cho nhà thầu quốc phòng (Sierra Nevada, STR) và qua Babel Street **Locate X** cho USSOCOM (~\$90.600). Consent-laundering qua chuỗi cung ứng SDK. [vice.com](https://www.vice.com).

- **Venntel/Babel Street "Locate X" → DHS/ICE/CBP — WSJ, 2/2020 (URL *paywall*)**. Data vị trí từ app bán như sản phẩm chính phủ: vẽ geofence, thấy device ID bên trong, bám theo thời gian; ICE định vị người nhập cư, CBP tìm đường hầm biên giới — không cần warrant (lỗ hổng hậu *Carpenter*). ACLU FOIA (2022): hàng trăm triệu điểm. [aclu.org](https://www.aclu.org). Liên quan: **Fog Reveal** — công cụ rẻ cho cảnh sát địa phương truy vấn ~250M thiết bị không warrant ([eff.org](https://www.eff.org)).

4. De-anonymization dataset (dữ liệu thật)

Ý nghĩa: định lượng vì sao bảo vệ per-point là chưa đủ — vài điểm không-thời-gian thừa và cặp nhà/chỗ-làm khiến bản thân quỹ đạo là định danh duy nhất. Biện minh cho **composition mức quỹ đạo (ε-T)** và đánh giá có tính đến tương quan. Bám kích bản **S6**.

- **de Montjoye et al., "Unique in the Crowd," Sci. Rep. 2013**. 1.5M user, 15 tháng CDR, độ phân giải giờ, ~114 tương tác/user/tháng. **4 điểm không-thời-gian ngẫu nhiên → 95% duy nhất; 2 điểm → >50%; ≤11 → 100%**. Tính duy nhất chỉ giảm ~lũy thừa 1/10 theo độ phân giải — làm thô gần như vô ích. [nature.com/articles/srep01376](https://www.nature.com/articles/srep01376). Follow-up "Unique in the shopping mall" (Science 2015): metadata thẻ tín dụng, **4 điểm → 90%**; thêm giá tiền **+22%** re-id. [science.org](https://www.science.org).
 - **NYC Taxi 2013/14**. (a) Pandurangan — 173M chuyến; MD5 của medallion/hack-license bị đảo (~22M ứng viên hash trong **<2 phút**), de-anon toàn bộ chuyến/thu nhập/nhà từng tài xế. [medium](https://www.medium.com). (b) Tockar (Neustar) "Riding with the Stars" — chuyến của sao từ ảnh paparazzi (**Bradley Cooper \$10.50 không tip; Jessica Alba \$9 không tip**); các pickup ngoài Hustler Club 00:00–06:00 → drop-off cụm → một địa chỉ có người ở → tra ra tên qua Spokeo/Facebook. [agkn.wordpress](https://www.agkn.wordpress.com).
 - **Golle & Partridge, "Home/Work Location Pairs," Pervasive 2009**. Census LEHD, 103M lao động. Kích thước tập ẩn danh cho cặp nhà/chỗ-làm: **1 ở mức census-block, 21 ở tract, 34.980 ở county** — biết nhà+chỗ-làm ở mức block khiến người trung vị là duy nhất. crypto.stanford.edu.
 - **Krumm, "Inference Attacks on Location Tracks," Pervasive 2007**. 172 tài xế, GPS. Bộ tìm nhà tốt nhất (Last Destination) sai số trung vị **60.7 m**; **~13% địa chỉ nhà đúng** (22/172) qua reverse geocoding; **~5% ra tên** (8–9/172) qua reverse white-pages. Cần: xoá bán kính 2 km, nhiễu σ 5 km, hoặc làm tròn 5 km mới vô hiệu hoá. [microsoft.com](https://www.microsoft.com) PDF.
 - **Giao thông / bike-share:** "Boris bikes" London mở data vẫn kèm customer ID — dựng lại 6 tháng của 1 commuter (nhà/chỗ-làm/quan hệ), Siddle 2014 ([vartree.blogspot](https://www.vartree.blogspot.com)). Kondor et al. (IEEE TBD 2020) — Singapore mobile (>2M user) vs smartcard EZ-Link: **17% khớp ở 1 tuần, >55% ở 4 tuần, ~95% ở ~11 tuần** ([arxiv 1709.05772](https://arxiv.org/abs/1709.05772)). Citi Bike 22.2M chuyến — {subscriber, giới, năm sinh, trạm, giờ} **định danh duy nhất 84% chuyến (92% với nữ)**; kể cả mức ngày vẫn 28% ([toddschneider](https://www.toddschneider.com)). (Không tìm thấy paper peer-reviewed de-anon mobility riêng cho OV-chipkaart/T-money — literature đó về crypto thẻ.)
 - **Landmark khác:** Zang & Bolot (MobiCom 2011) — CDR toàn quốc, **top-2 vị trí (≈nhà+chỗ-làm) định danh duy nhất ~35%** trên 25M user, tới **50%** khi có social side-info; rotate ID hàng ngày giảm còn ~3% (dl.acm.org) (flag: quy mô dataset các nguồn thứ cấp ghi khác nhau). Gambis et al. (JCSS 2014) — Mobility Markov Chains re-id **~42–45%** trên GeoLife/Nokia, bền với downsampling ([hal.science](https://www.hal.science)). Song et al. (Science 2010) — **93% predictability** của di chuyển người ([science.org](https://www.science.org)). Baseline Sweeney: **87%** người Mỹ duy nhất trên {DOB, giới, ZIP}.
-

5. Tấn công lên dữ liệu đã obfuscate (gắn cơ chế deploy/Geo-I)

Ý nghĩa: đây là các tấn công cơ chế của luận văn PHẢI sống sót; vài cái đã có code trong [evaluation/attacks.py](#). Bám kích bản **S2, S3, S4, S5**.

- **Averaging / báo cáo lặp (phá rounding, grid-snap, Geo-I lặp từ điểm tĩnh).** Nền tảng: Andrés et al. (CCS 2013) chứng minh báo cáo độc lập n điểm chỉ cho **nc-Geo-I** ("privacy giảm tuyến tính theo n "), và nêu rõ báo cáo cùng 1 điểm 2 lần $\rightarrow$ giảm privacy, nên trung bình hoá nhiều Laplace zero-mean qua nhiều báo cáo của một điểm nhà tính sẽ hội tụ về sự thật. Thực nghiệm dữ liệu thật: Mendes, Cunha, Vilela (PoPETs 2020) — trên GeoLife, **tracking error tăng khi tần suất báo cáo tăng**; $\epsilon \geq 8 \text{ km}^{-1}$ "gần như không bảo vệ"; thêm tấn công **map-matching HMM dạng tracking đầu tiên**. Tương tự thực tế = khôi phục nhà EPZ Strava (84–95%). [arxiv 1212.1984](#); [petsymposium 2020](#). Tiền lệ cơ chế dự báo: Chatzikokolakis et al. (PETS 2014, [arxiv 1311.4008](#)).
- **Bayesian optimal inference / remapping (có prior).** Shokri et al. (S&P 2011) — localization attack + **expected estimation error** là metric đúng (k-anonymity/entropy không tương quan với bảo vệ thật); đây chính là [BayesianPointAttack](#) $\rightarrow$ [expected_inference_error](#). Shokri et al. (CCS 2012) — game Stackelberg: mọi LPPM cố định đều có **attacker Bayes tối ưu tương ứng**. Oya, Troncoso, Pérez-González (CCS 2017, "Back to the Drawing Board") — cơ chế tối ưu cho error *trung bình* (Geo-I trong đó) có worst-case tệ / conditional entropy thấp, nên adversary có prior làm tốt hơn metric trung bình gọi ý; EuroS&P 2019 — privacy bị *đánh giá cao quá* khi prior thiết kế $\neq$ hành vi thật. Chatzikokolakis et al. (PoPETs 2017) — remap Bayes cải thiện trade-off error, tức output planar-Laplace không Bayes-optimal $\rightarrow$ remap được. [ieee-security PDF](#); [arxiv 1705.08779](#).
- **Tương quan thời gian trên chuỗi DP/Geo-I.** Xiao & Xiong (CCS 2015) — adversary có **Markov mobility model** + báo cáo quá khứ phá DP per-timestamp; giới thiệu δ -location-set DP + PIM. Đây là analogue rời rạc mà [HMMTrackingAttack](#) cài $\rightarrow$ [tracking_error](#). Cao et al. (ICDE 2017 / TKDE 2019) — privacy loss hiệu dụng **tích lũy theo thời gian** vượt ϵ per-release. Mendes et al. (CODASPY 2023) — Velocity-Aware Geo-I: map-matching + tương quan vận tốc làm yếu Geo-I (tiền thân trực tiếp của thiết kế reachability-aware = T-REM). [arxiv 1410.5919](#); [arxiv 1711.11436](#).
- **Map-matching / khử nhiễu theo ràng buộc đường.** Takagi et al. (GG-I, arXiv:2010.13449) — adversary biết đồ thị đường loại bỏ khối lượng off-road của planar-Laplace và remap lên đường, giảm privacy hiệu dụng; biện minh cho **Graph-Exponential Mechanism** (REM của bạn là anh em Euclid). Trong benchmark của bạn đây là lý do [PlanarLaplace](#) để 32–42% điểm off-road còn REM/T-REM 100% on-road. [arxiv 2010.13449](#).
- **Velocity / reachability linkage tracking.** Ghinita et al. (SIGSPATIAL GIS 2009) — **maximum-movement-bound attack**: reachability ($v_{\max} \cdot \Delta t$) giữa các vùng cloak liên tiếp thu nhỏ từng vùng. Gambs et al. (JCSS 2014) — linkage MMC. HMM/Viterbi tracking (Shokri, Xiao-Xiong, Mendes) chọn đường thật khả dĩ nhất từ quan sát obfuscated, tĩa các transition vi phạm reachability. Đây là cái [speed_violation_rate](#) và [HMMTrackingAttack](#) nhắm tới, và là cái reachability weighting của T-REM đóng lại. [dl.acm.org/1653807](#). (*Particle filter riêng vs Geo-I: kỹ thuật chung, không có paper canonical gán tên.*)
- **Lọc dummy / k-anonymity cloaking.** Shokri et al. (WPES 2010) — k-anonymity không hàm ý adversary success thấp. Peddinti & Saxena (UbiComp 2011) — tương quan chuyển nâng nhận diện dummy-vs-thật từ **~20% lên ~40%**. Các lớp lọc dummy: phân bố xác suất ("dummy giữa hồ"), map-aware (vị trí bất khả thi), reachability/thời gian. Bettini et al. (SDM 2005) — chuỗi request là quasi-identifier. Biện minh việc bỏ k-anonymity/dummy để dùng ϵ -Geo-I-trên-đường hình thức. [carmelatroncoso PDF](#).

6. Taxonomy 8 kịch bản (S1–S8) → ánh xạ phòng thủ

Mỗi lớp: (a) năng lực đối thủ, (b) data thấy, (c) thuộc tính phòng thủ hoá giải — và gắn với `core/mechanisms.py` + `evaluation/`.

#	Lớp tấn công (ví dụ thật)	(a) Năng lực đối thủ	(b) Data thấy	(c) Phòng thủ hoá giải → cơ chế / metric
S1	Localization / trilateration oracle (Tinder, Grindr, Bumble, happn)	Query dịch vụ lập, spoof vị trí, biết luật rounding/filter	distance / rounded distance / oracle proximity nhị phân	Chặn likelihood-ratio ϵ-Geo-I hình thức để mọi điểm gần nhau bất khả phân biệt; distance suy từ release đã lượng tử/on-road , không từ toạ độ thô → REM . Rounding/hide-distance tự chế <i>không</i> là guarantee — lớp này là bằng chứng thực nghiệm. Lưu ý: query lập cần budget accounting (xem S4).
S2	Map-matching / plausibility-filter / tia off-road (Takagi; RAoPT; khe hở "snap to street")	Biết mạng đường	chuỗi điểm đã release	On-road theo cấu trúc — không còn khối off-road để loại, không có snap để đảo → REM/T-REM ; đo bằng on_road_rate (PlanarLaplace 0.58–0.68 vs REM/T-REM 1.00). Đây là lập luận trung tâm REM > "planar-Laplace rồi snap".
S3	Velocity/reachability linkage + HMM/Markov tracking (Ghinita; Xiao-Xiong; Mendes; Gambis)	Biết $v_{\max}$ + mobility/Markov model + toàn chuỗi release + timestamp	quỹ đạo release + thời gian	Reachability weighting chỉ điều kiện theo điểm ĐÃ release → fake khả thi động học mà filter reachability không tĩa được, ϵ per-point không đổi → T-REM ; đo bằng speed_violation_rate (REM 0.35 → T-REM 0.06 ở $\epsilon=0.01$) và HMMTrackingAttack / tracking_error . Smoothing heuristic của baseline không có guarantee.
S4	Averaging / báo cáo lặp từ điểm tĩnh (Andrés n ϵ ; Mendes PoPETs'20; EPZ Strava 84–95%; fingerprint nhà của broker/NYT)	Thu nhiều release của cùng điểm thật theo thời gian	release lặp từ một chỗ	Đừng phát nhiều độc lập mới cho cùng điểm thật: memoization / nhiều tương quan (dự báo) + kế toán ϵ-T mức quỹ đạo . <i>Khe hở thành thật:</i> cả 4 cơ chế hiện chưa memoize — T-REM chỉ giúp một phần (ràng buộc successor, không ràng buộc thăm lại). Ghi làm future work; báo cáo ϵ_{total} .
S5	Bayesian optimal inference / remapping có prior (Shokri S&P'11, CCS'12; Oya CCS'17; Chatzikokolakis PoPETs'17)	Biết cơ chế (Kerckhoffs) + prior mobility	điểm đã release	Giữ nguyên chặn ϵ — KHÔNG cap/reject/re-check theo điểm thật (chính vì thế BaselineThesis sai: cap + QoS-recheck điều kiện theo vị trí thật). Support on-road có prior thu hẹp lợi ích remap; đánh giá bằng expected_inference_error với adversary có <i>prior</i> . Thành thật: không cơ chế cố định nào thoát optimal attack — guarantee Geo-I là worst-case theo prior. → REM/T-REM + BayesianPointAttack .
S6	Re-id qua tính duy nhất nhà/chỗ-làm + linkage phụ trợ (de Montjoye 4→95%; Golle-Partridge block-unique; Zang-Bolot; Krumm; NYC taxi; Citi Bike; NYT; linh mục)	Có quỹ đạo "ẩn danh"/pseudonym đầy đủ + hồ sơ công khai (cử tri, bất động sản, social)	quỹ đạo đầy đủ dưới pseudonym bền	Nhiều per-point đơn lẻ không hoá giải hết — <i>quỹ đạo</i> là định danh. Hoá giải bằng composition mức quỹ đạo (ϵ-T) đầy mỗi điểm đủ xa + báo cáo expected inference error; về bản chất là mối đe dọa <i>publication/linkage</i> . Dùng để biện minh (i) đánh giá mức quỹ đạo, không per-point, và (ii) pseudonym $\neq$ privacy. Chủ yếu motivation, một phần in-scope.
S7	Thất bại aggregation ở mật độ thấp (Strava heatmap → căn cứ; NC State ID nhà)	Đọc aggregate/heatmap; mật độ user thấp	raster tổng hợp	k-anonymity / suppress mật độ tối thiểu cho mọi release tổng hợp. Ngoài phạm vi LPPM nhiều per-user, nhưng liên quan nếu pipeline publish aggregate — ghi chú và trích như failure mode riêng.

#	Lớp tấn công (ví dụ thật)	(a) Năng lực đối thủ	(b) Data thấy	(c) Phòng thủ hoá giải → cơ chế / metric
S8	Lỗi API / side-channel / hệ thống & chuỗi cung ứng (Polar API, segment giả, S3 mở, resale SDK/RTB, lộ broker)	Truy cập API quá rộng, ad bidstream, hoặc corpus rò rỉ	data thô lưu trữ, không obfuscate	Ngoài phạm vi cơ chế nhiều — access control, rate limit, thiết kế API, retention/consent, ứng phó breach. Đưa vào luận văn như biên giới của những gì LPPM hứa được.

7. Khuyến nghị bước tiếp theo (bám [Notes.md](#))

Sắp theo impact/effort. Mấy cái đầu dùng được ngay dữ liệu/khung này.

1. **Viết chương "Threat Model & Evaluation Scenarios" từ taxonomy S1–S8.** Đây là đóng góp "grounded in reality" mà đề bài nhắm tới. Với mỗi Sx: 1 sự cố thật minh hoạ + định nghĩa hình thức adversary + metric tương ứng. S1/S2/S3/S5 đã có code; chỉ cần viết + dẫn benchmark trong [research_notes.md](#). → phục vụ TODO "attack methods" và "dataset → metrics → algorithms → attack methods".
 2. **Bịt khe hở S4 (averaging/retry) — đúng TODO "note retry mechanism" trong [Notes.md](#).** Hiện là lỗ hổng thật chưa cơ chế nào xử. Hai việc: (a) thêm **memoization** (cache release theo cell/vertex để thăm lại cùng chỗ trả cùng fake) hoặc **predictive release** (Chatzikokolakis PETS'14); (b) thêm thí nghiệm "báo cáo N lần từ một điểm nhà tĩnh → sai số adversary theo N" để định lượng, so 4 cơ chế. Nêu Andrés (ne) + Mendes PoPETS'20 làm attack neutralize. Đây là điểm phản biện reviewer hay bắt (đánh giá per-point) — bịt trước là lợi thế.
 3. **Chạy RAOPT (code công khai) đối kháng 4 cơ chế** — bar tối thiểu SoK 2024, cụ thể hoá S2. Kỳ vọng: REM/T-REM (100% on-road) làm RAOPT mất bề mặt plausibility-filter mà PlanarLaplace/ baseline để lộ. Đây là thí nghiệm mạnh nhất để "chứng minh on-road-by-construction".
 4. **Thí nghiệm S1 (trilateration/oracle) dạng LBS query.** Bám TODO "POI" + "infra local/middleware": mô phỏng adversary query lập qua middleware, đo thông tin rò per-query dưới REM có budget vs rounding/grid-snap. Nối được với khung KU Leuven (3 lớp trilateration) — cầu nối trực tiếp giữa "sự cố app thật" và cơ chế formal.
 5. **Adaptive QoS radius / ϵ** (TODO có sẵn): dùng elastic/semantic metric trên graph. Cảnh báo lỗi kinh điển (research_notes §3.1): **chọn ϵ /QoS phụ thuộc vị trí THẬT $\Rightarrow$ tự rò rỉ** (giống lỗi cap của baseline ở S5). Thiết kế phải điều kiện theo public info (như T-REM). Có thể là khe publishable ("elastic GG-I" chưa ai làm).
 6. **Mở rộng related works** (TODO "add more related works"): file này cung cấp sẵn cụm tấn công + citation để lấp Chapter 3 — nhất là nhánh attack (Shokri, Xiao-Xiong, Oya, Ghinita, Takagi, RAOPT) và nhánh de-anon thực tế (de Montjoye, Golle-Partridge, Krumm) làm motivation Chapter 1.
- Ưu tiên đề xuất:** (2) và (3) trước — chúng biến hai luận điểm trung tâm (REM chống map-matching, gap averaging) thành số thực nghiệm; rồi (1) để đóng gói thành chương; (4)(5)(6) mở rộng nếu còn thời gian.

8. Điểm chưa chắc chắn (carry từ nguồn)

- Vụ lộ Gravy "17 TB" là con số của attacker (mẫu phân tích ~30M bản ghi).
- Công ty nguồn dataset NYT và vendor data của The Pillar chưa từng bị nêu tên công khai.
- Quy mô dataset Zang & Bolot khác nhau giữa các nguồn thứ cấp (các % duy nhất thì nhất quán).
- % GeoLife/Nokia của Gambs là khoảng paper báo cáo.
- Không có paper canonical particle-filter-riêng-vs-Geo-I (kỹ thuật chung; HMM/Viterbi thì rõ nguồn).
- Không tìm thấy de-anon mobility peer-reviewed riêng cho OV-chipkaart/T-money.
- Vài URL primary (Include Security, Guardian, NYT, WSJ) chặn fetch tự động nhưng xác nhận qua thứ cấp.